

Dispute Chamber

Decision on the merits 65/2025 of April 3, 2025

File number: DOS-2021-06312

Subject: The violation of the confidentiality of personal data

The Dispute Chamber of the Data Protection Authority, composed of Mr. Hielke HIJMANS, chair, and Messrs. Dirk Van Der Kelen and Frank De Smet, members;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter referred to as “GDPR”;

Considering the law of December 3, 2017, establishing the Data Protection Authority, hereinafter referred to as “WOG”;

Considering the internal rules of procedure, as approved by the Chamber of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Considering the documents in the file;

Has made the following decision regarding:

The respondent:

Federal Public Service Interior, hereinafter FOD IBZ, with registered office at 1000 Brussels – Leuvenseweg 1, registered in the Crossroads Bank for Enterprises under number 0308.356.862, represented by Mr. Bart Martel, Mr. Anneleen Van de Meulebroucke, and Mr. Laura Deschuyteneer, hereinafter referred to as “the respondent.”

Decision on the merits 65/2025 — 2/9

I.

Facts and procedure

1.

Between January 24, 2020, and January 28, 2020, thousands of eID certificates (both signature and authentication certificates) were registered in a certificate transparency log system (CT-logs) of Google. The certificates contained personal data, including the national register number (as the serial number of the subject of the certificate), the name and first name of the citizen, and the fact that it concerns a Belgian national or a foreigner.

2.

On October 22, 2021, the Executive Committee of the Data Protection Authority (hereinafter “GBA”) decided to initiate a case with the Inspection Service of the GBA based on Article 63, 1° WOG¹ as it was applicable at the time of the facts that led to the present procedure (hereinafter referred to as WOG) since the Executive Committee was of the opinion that there were serious indications pointing to a practice that could lead to a violation of the fundamental principles of the protection of personal data.

3.

On September 8, 2022, the investigation by the Inspection Service was completed, the report was added to the file, and the file was forwarded by the Inspector General to the Chair of the Dispute Chamber (Article 91, § 1 and § 2 WOG). The report contains findings regarding the subject of the complaint and concludes that there is:

1. a violation of Article 5.1, f) in conjunction with Article 32 GDPR as there would be no adequate security of personal data;

2. a violation of Article 5.2 and Article 24.1 GDPR as the respondent would not fully assume responsibility;

3. a violation of Article 25 GDPR as the respondent would not apply data protection by design;

4. a violation of Articles 33 and 34 GDPR as the respondent would not have reported the data breach and would not have informed the affected citizens; and

5. a violation of Article 35 GDPR as the respondent conducted an impact assessment regarding data protection in the context of the processing with the eID but there would be neither an update of the

impact assessment in light of the issues of this file nor a plan for updating it.

1

Article 63, 1° (former) WOG:

Art. 63. The initiation with the inspection service can occur:

1° when the executive committee establishes serious indications of the existence of a practice that may lead to a violation of the fundamental principles of the protection of personal data, within the framework of this law and the laws that contain provisions regarding the protection of the processing of personal data.

Decision on the Merits 65/2025 — 3/9

4.

On September 30, 2022, the Dispute Chamber decides based on Article 95, § 1, 1° and Article 98 WOG that the file is ready for substantive treatment.

5.

On September 30, 2022, the respondent is notified by registered mail of the provisions as mentioned in Article 95, § 2, as well as those in Article 98 WOG. She is also informed under Article 99 WOG of the deadlines for submitting her defenses. The deadline for receipt of the respondent's statement of defense is set for November 11, 2022.

6.

On October 25, 2022, the respondent requests a copy of the file (Article 95, § 2, 3° WOG), which is provided to her on October 28, 2022.

7.

On October 27, 2022, the respondent electronically accepts all communication regarding the case and indicates her wish to make use of the opportunity to be heard, in accordance with Article 98 WOG.

8.

On November 3, 2022, the respondent requests an extension regarding the final date for the submission of conclusions. The new deadline for receipt of the respondent's statement of defense is set for December 15, 2022.

9.

On November 7, 2022, the parties are informed that the hearing will take place on January 24, 2023.

10.

On December 15, 2022, the Dispute Chamber receives the statement of defense from the respondent.

11.

On January 20, 2023, the respondent requests to postpone the hearing. On January 23, 2023, the respondent is informed that the hearing will take place on March 16, 2023.

12.

On March 16, 2023, the respondent is heard by the Dispute Chamber. During the hearing, the possibility of exploring an amicable solution in this case is discussed, including the instrument mentioned in Article 100, § 1, 4th of the WOG regarding a settlement proposal.

13.

On March 22, 2023, the minutes of the hearing are submitted to the parties.

14.

On March 29, 2023, the Dispute Chamber receives some comments from the respondent regarding the minutes, which it decides to include in its deliberation.

15.

On August 28, 2023, the respondent is informed that a new hearing will take place on September 25, 2023. The respondent is heard on September 25, 2023.

Decision on the Merits 65/2025 — 4/9

16.

On September 10, 2024, the Dispute Chamber informs the respondent of its intention to proceed with a settlement and presents a settlement proposal.

17.

On March 21, 2025, the Dispute Chamber withdraws the settlement proposal (as a settlement within a

relatively short period proved unfeasible), thereby continuing the substantive procedure.

II. Reasoning

18.

The law of July 19, 1991, concerning the population registers, identity cards, foreigner cards, and residence documents regulates, among other things, the electronic identity card (hereinafter: "eID"). The eID contains two certificates: the signature certificate and the authentication certificate, which contain various personal data of the citizen, including the national register number.

19.

The respondent is the data controller for the issuance of eIDs and also places these certificates on them in accordance with the European Regulation (EU) 2019/1157 and the European eIDAS Regulation. These authentication and signature certificates are public.

20.

Every citizen can decide whether to activate the certificates and with whom to share the certificates. The citizen shares his certificates with a third party when he needs to identify himself and, if applicable, authenticate (such as when logging in online to a web application or when scanning the eID) or when he digitally signs a document and provides this document to a third party. These certificates contain the national register number of the citizen as the serial number. The electronic signature and/or authentication certificates that contain the national register number may be retained without prior consent as long as necessary to provide proof of the

2 BS September 3, 1991.

3 The two types of certificates contain by design the following (personal) data of the citizen:

- a. A serial number equal to the national register number,
- b. The first names
- c. The last name
- d. The country
- e. Validity period (start/end)
- f. Type of use i. Non-repudiation (for Signature) ii. Digital Signature (for Authentication)
- g. The public key

4 See in particular Annex I of Regulation (EU) 2019/1157 of the European Parliament and the Council of June 20, 2019, concerning the strengthening of the security of identity cards of Union citizens and residence documents issued to Union citizens and their family members exercising their right to free movement, OJ L 188/67, July 12, 2019, and Article 6 of Regulation (EU) No. 910/2014 of the European Parliament and the Council of July 23, 2014, concerning electronic identification and trust services for electronic transactions in the internal market, repealing Directive 1999/93/EC, OJ L 257/173, August 28, 2014 (hereinafter "eIDAS Regulation").

Decision on the Merits 65/2025 — 5/9

electronic signature or authentication (Article 8, §3, fourth paragraph of the Act of August 8, 1983 regulating a National Register of Natural Persons).

21.

The certificates, which are freely available for citizens to use for identification/authentication or to place an electronic signature, contain personal data, making the GDPR applicable to the processing of this personal data. Publishing it elsewhere or sharing it with third parties or otherwise processing it is therefore not permitted without proper authorization. The National Register Act even prohibits the unlawful use of the national register number without authorization and for purposes other than those for which the authorization was granted (Article 8, §8, paragraph 2 of the National Register Act). Criminal sanctions apply to this (Article 13, paragraph 2 of the National Register Act).

22.

The disputed processing in this case is the unlawful publication of approximately 40,000 signature and authentication certificates of Belgian citizens in one of Google's CT logs, which violated the confidentiality of the personal data. The question arises as to who should be designated as the data controller for this disputed processing.

23.

According to Article 4.7) GDPR, the data controller is to be understood as: “the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing of personal data.” The data controller must therefore have decision-making authority and influence over the relevant processing of personal data.

24.

The Inspection Service states in its report that the respondent must be qualified as the data controller for the disputed processing. To this end, the Inspection Service presents the following arguments. First, the respondent is responsible for safeguarding the identity of the citizen: the respondent produces and distributes, among other things, the eIDs in accordance with what is stated on the respondent's website. Second, the Inspection Service points out that the respondent, after consulting with the Federal Public Service Policy and Support (FOD BOSA), responded to the questions during the inspection investigation. The Inspection Service notes that information from the Crossroads Bank for Enterprises (KBO) also indicates that the respondent should be considered the data controller. They attach an excerpt of this to the report.

5 BS April 21, 1984.

6 Act of August 8, 1983 regulating a National Register of Natural Persons, BS April 21, 1984.

7 EDPB Guidelines 7/2020 on the concepts of “data controller” and “processor” in the GDPR 2.0, July 7, 2021, 12.

8 The FOD BOSA is responsible for the Belgium Root CA with which the Citizen CA and Foreigner CA are signed.

Decision on the Merits 65/2025 — 6/9

25.

The respondent disputes this qualification as data controller and refutes the findings of the Inspection Service. They acknowledge that they are indeed responsible for the issuance of, among other things, the eID cards but argue that this does not say anything about the disputed processing in this case, namely the publication of the certificates on the CT logs. The respondent places the certificates on the citizens' eIDs, but neither the respondent nor FOD BOSA, nor their subcontractors publish these certificates at any other location. Regarding the fact that they answered the questions from the Inspection Service, the respondent points out that they consulted with FOD BOSA and that during that consultation it was agreed that they would respond to the questions posed. According to the respondent, a qualification as data controller for the publication of the certificates on the CT logs cannot be inferred from the fact that they answered questions from the Inspection Service. Moreover, they have repeatedly indicated in their communications with the Inspection Service that they are not the data controller for the disputed processing. Regarding the last finding concerning the excerpt from the KBO, the respondent is unclear about what the Inspection Service means by this. The excerpt as included in the Inspection Report contains no substantive indications regarding the processing of personal data in any context, let alone about the eID and more specifically about the publication of the certificates on the CT logs, the respondent concludes.

26.

It is up to the Dispute Chamber to assess whether the respondent should be designated as the data controller for the disputed publication of the certificates on the CT logs.

27.

The Dispute Chamber points out that a data controller is responsible for its own processing “carried out by or on behalf of it” (Recital 74 GDPR). The Court of Justice has ruled on this point that a data controller cannot be held responsible for earlier or later processing for which it has not determined the purpose and means:

“On the other hand, that natural or legal person, without prejudice to any civil liability provided for by national law in this regard, cannot be considered to be responsible in the sense of that provision for processing operations that take place earlier or later in the processing chain and for which it has not determined the purpose and means.”

28.

The guidelines 07/2021 on the concepts of “data controller” and “processor” in the GDPR from the

European Data Protection Board (EDPB) also state that the qualification as data controller or processor must be assessed with

9 CJEU July 29, 2019, case C-40/17, ECLI:EU:C:2019.629, Fashion ID, para 74.

Decision on the merits 65/2025 — 7/9

regarding

any

specific

processing

activity.

The

qualification

as

data controller does not simply arise from the nature of the entity processing the data, but from its concrete activities in a specific context.¹⁰ The fact that the respondent's website states that it monitors the identity of the citizen and issues eIDs, among other things, does not mean that it would automatically be the data controller for all processing of personal data that occurs with the involvement of the eID, such as in the further use of the eID and the certificates placed on it by a citizen or a third party, for example, in the publication of personal data in the CT logs.

29.

The Dispute Chamber does not have elements indicating that the respondent decided to proceed with the publication of the certificates in the CT logs, nor does it have information on how and why this publication would take place. The Inspection Service also states in its report that “the processing by the CT ecosystem was indeed not determined as a purpose by the [the respondent].”

30.

After investigation by the respondent and other involved actors such as Google, it is unclear who published the certificates in the CT logs. Since CT logs are an open-source platform and are intended to prevent erroneous or fraudulent certificates, anyone can (and must) upload certificates to the CT logs. Google does not keep extensive logs of who publishes something in its CT logs. Consequently, Google itself cannot determine who published the certificates in the CT logs.

31.

In light of the above, the Dispute Chamber concludes that it is not established that the respondent de jure or de facto determined the purpose and means of the disputed publication of the certificates and that the respondent cannot therefore be designated as the data controller in this context.

32.

Consequently, the Dispute Chamber does not uphold the findings of the Inspection Service and decides to proceed with a technical dismissal in accordance with its dismissal policy.¹¹

33.

However, the Dispute Chamber points out that neither the National Register Act nor the GDPR allows for the publication of these certificates and the associated personal data in CT logs without an applicable legal basis. The personal data in question includes the national register number (as the serial number of the certificate), the unique key to many authentic personal data of the citizen. The use of these certificates makes the national register number public, as in the case of a digital signature or online authentication. However, the unlawful leaking of thousands of certificates to the CT logs results in an extreme magnification of this vulnerability in terms of

¹⁰ EDPB Guidelines 7/2020 on the concepts of “data controller” and “processor” in the GDPR 2.0, July 7, 2021, 14.

¹¹ See also decision 117/2021 dated October 22, 2021, and the Dismissal Policy of the Dispute Chamber of June 18, 2021, under 3.1.A, available at <https://www.gegevensbeschermingsautoriteit.be/publications/sepotbeleid-van-de-geschillenkamer.pdf>.

Decision on the merits 65/2025 — 9/9

the petition for opposition must be submitted to the registry of the Market Court in accordance with

Article 1034quinquies of the Ger.W.14, or via the e-Deposit information system of Justice (Article 32ter of the Ger.W.).

(Get). Hielke HIJMANS

Chairman of the Dispute Chamber

1° the day, the month, and the year;

2° the name, first name, residence of the petitioner and, where applicable, their capacity and their national register or business number;

3° the name, first name, residence and, where applicable, the capacity of the person to be summoned;

4° the subject and a brief summary of the grounds of the claim;

5° the judge before whom the claim is brought;

6° the signature of the petitioner or their lawyer.

14 The petition with its annex is sent by registered letter to the clerk of the court or filed at the registry in as many copies as there are parties involved.